公開ウェブサイト セキュリティ対策実施報告書

対象サイト：パネルタンク・クーリングタワー ナビゲーター

項目	内容
提出先	三菱ケミカルインフラテック株式会社 御中
対象URL	https://mchem-infratec.com/setu/ （パネルタンク：/setu/tank/、クーリングタワー：/setu/tower/）
届出種別	変更
報告日	2026年11月6日
作成	株式会社TEGOS

1. はじめに

本書は、「公開ウェブサイト セキュリティ対策チェックリスト（別紙2）」の各項目について、当サイトでの対策の実施状況を、設定画面・動作確認結果などの記録とあわせてご報告するものです。

当サイトは当初、三菱ケミカル様の基盤上での運用を予定していましたが、より高い水準のセキュリティを確保するため、**Amazon Web Services（AWS）東京リージョン上に当サイト専用の環境を新たに構築**しました。あわせて、貴社のセキュリティ要件に沿って、不正アクセス対策・改ざん検知・管理画面の保護などを追加で実施しています。

チェックリスト全48項目の対応状況は次のとおりです。

区分	件数	説明
実施済	34	構築時に対策を完了し、設定を確認済みの項目
実施予定	2	公開日までに対応を予定している項目
公開後の定期運用	9	公開後に月次・年次で継続して実施する項目
対象外	3	当サイトに該当機能がない、または別方式で構築している項目
合計	48	

2. システム構成の概要

当サイトは、既存の貴社ドメイン（mchem-infratec.com）配下のURLを維持したまま、アクセンチュア様管理のWebサーバから当サイト専用環境へ転送する構成としています。

閲覧者からのアクセスは、次の順に経由します。

順	経由先	役割・セキュリティ対策
1	閲覧者のブラウザ	HTTPSで公開URL（mchem-infratec.com/setu/）へアクセス
2	貴社既存Webサーバ（アクセンチュア様管理）	/setu/ 配下のみを当サイト専用環境へ転送（HTTPS）
3	Amazon CloudFront ＋ AWS WAF	不正通信の遮断、過剰アクセスの制限、DDoS対策
4	ロードバランサ（ALB）	Webサーバへの通信の振り分け
5	Webサーバ（Amazon Linux 2023／Apache／PowerCMS）	サイトの配信。管理用の通信は許可IPのみ
6	データベース（Amazon RDS for MySQL）	Webサーバからのみ接続可能（インターネットから直接接続不可）

3〜6はすべてAWS東京リージョン上の当サイト専用環境です。あわせて、Amazon GuardDuty（脅威検知）、CloudWatch（ログ保管）、改ざん検知で常時監視しています。

構成要素	採用技術	バージョン
OS	Amazon Linux 2023	2023.12（2029年6月までサポート）
Webサーバ	Apache HTTP Server	2.4.69
CMS	PowerCMS	6.84
実行環境	Perl / PHP	5.32.1 / 8.4.27
データベース	Amazon RDS for MySQL	8.4.11

3. 項目別の対応状況

各項目の「結果」はチェックリスト（別紙2）の記載と対応しています。

3.1 構築：システム基盤

No.01 MCC標準サービスの利用 — 対象外

MCC標準サービスではなく、AWS東京リージョン上に当サイト専用の環境を構築しています。既存URL（mchem-infratec.com/setu/）はそのまま維持し、アクセンチュア様管理のWebサーバから当サイト環境へ転送しています。このため、本書では No.2〜13、22、40 についても個別に対策状況をご報告します。

転送設定（アクセンチュア様Webサーバ側）では、当サイトに必要な `/setu/` 配下のみを転送対象としています。

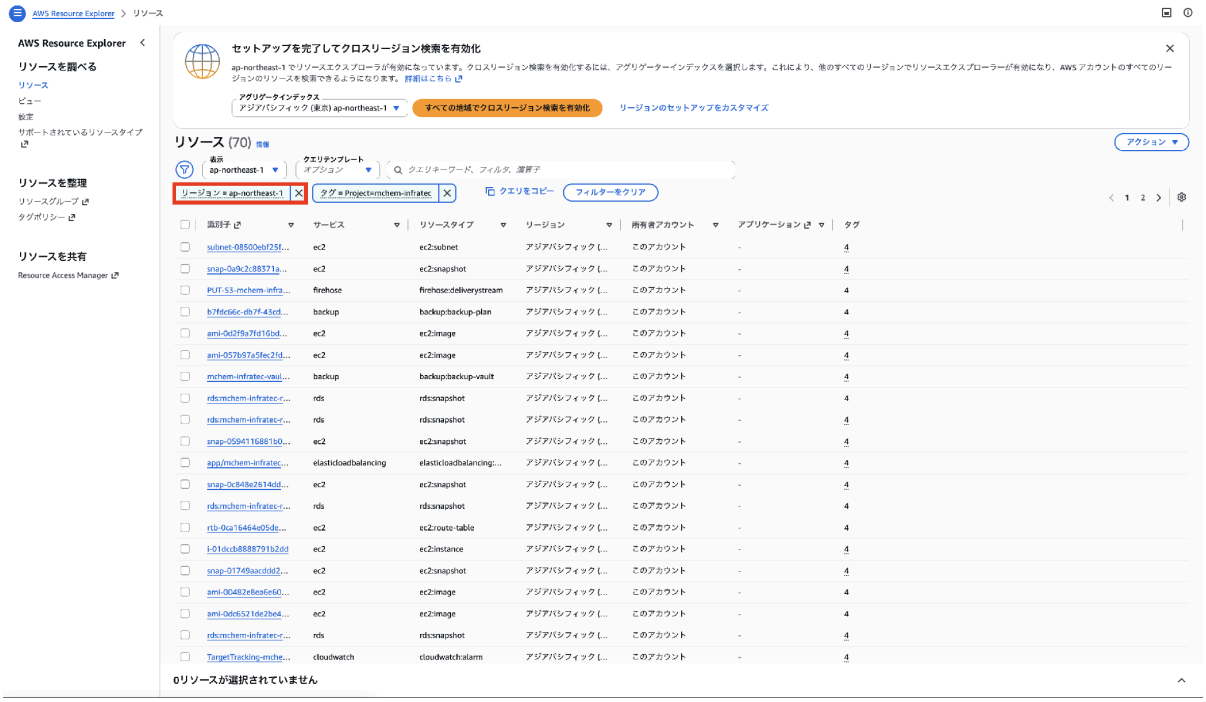
```
# 転送先（当サイト専用環境）
Define DIST_DOMAIN https://d3gy3iazm05cpf.cloudfront.net

<Location "/setu/">
    ProxyPass "${DIST_DOMAIN}/setu/"
</Location>
```

No.02 ファシリティセキュリティ — 実施済

AWS東京リージョン（ap-northeast-1）を利用しています。データセンターの災害対策・入退室管理・空調・電源などの物理的な管理はAWSの責任範囲であり、AWSは **SOC 2 Type II、ISO/IEC 27001・27017・27018 の認証を取得し、ISMAP（政府情報システムのためのセキュリティ評価制度）にも登録** されています。

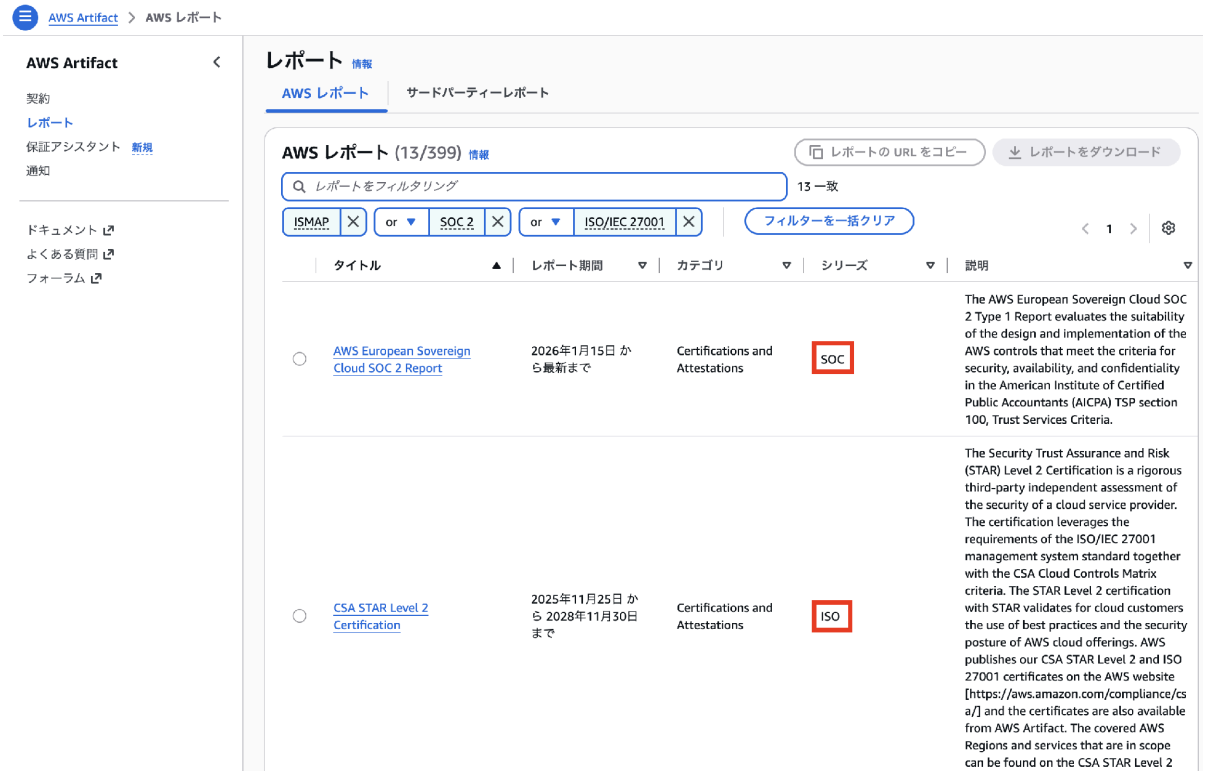
当サイトの全リソースが東京リージョンに構築されていることを確認しています。



▲ 当サイトのリソースがすべて東京リージョンに配置されていることの確認



▲ AWS責任共有モデル（物理的なセキュリティはAWSの責任範囲）



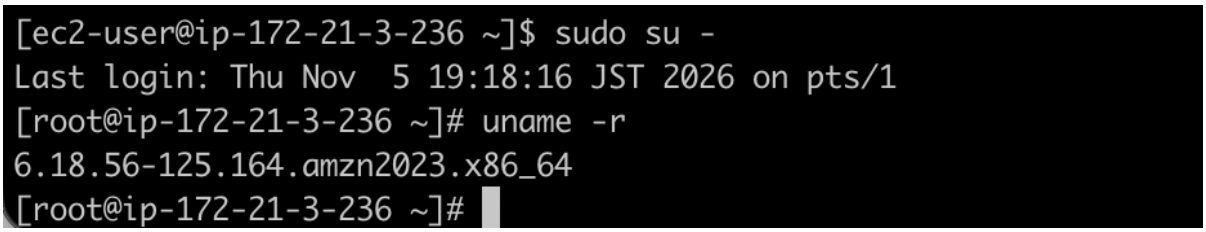
▲ AWSが取得している第三者認証（SOC 2、ISO/IEC 27001、ISMAP）

No.03 OS・ミドルウェアの最新化 — 実施済

OS・Webサーバ・実行環境は、提供元（AWS）が配布するセキュリティ更新を適用して運用しています（バージョンは「2. システム構成の概要」参照）。CMS（PowerCMS）は 6.84 へバージョンアップ済みで

す。データベースはAWSのマネージドサービス（Amazon RDS）を利用しており、パッチは自動適用されます。

セキュリティ更新を適用してサーバを再起動し、更新後のカーネル（6.18.56）で稼働していることを確認しています。



▲ セキュリティ更新適用後のカーネルで稼働していることの確認

No.04 構成管理 — 実施済

OS・ミドルウェア・CMS・プラグインのバージョンを設計書で管理し、プログラムはバージョン管理システム（Git）で変更履歴を管理しています。サーバに導入されているソフトウェアの一覧は取得・保管しており、新たな脆弱性情報が公表された際に影響の有無をすぐ確認できる状態です。

No.05 不要なサービスの停止 — 実施済

Webサーバ・CMSの動作と、監視・ログ収集・セキュリティ対策に必要なサービスのみを稼働させ、それ以外は停止または未導入としています。

稼働中の主なサービス：Webサーバ（Apache）、CMS実行環境、脅威検知（Amazon GuardDuty）、ログ収集（CloudWatch）、監査ログ（auditd）、時刻同期 など

No.06 ファイル・ディレクトリのアクセス制御 — 実施済

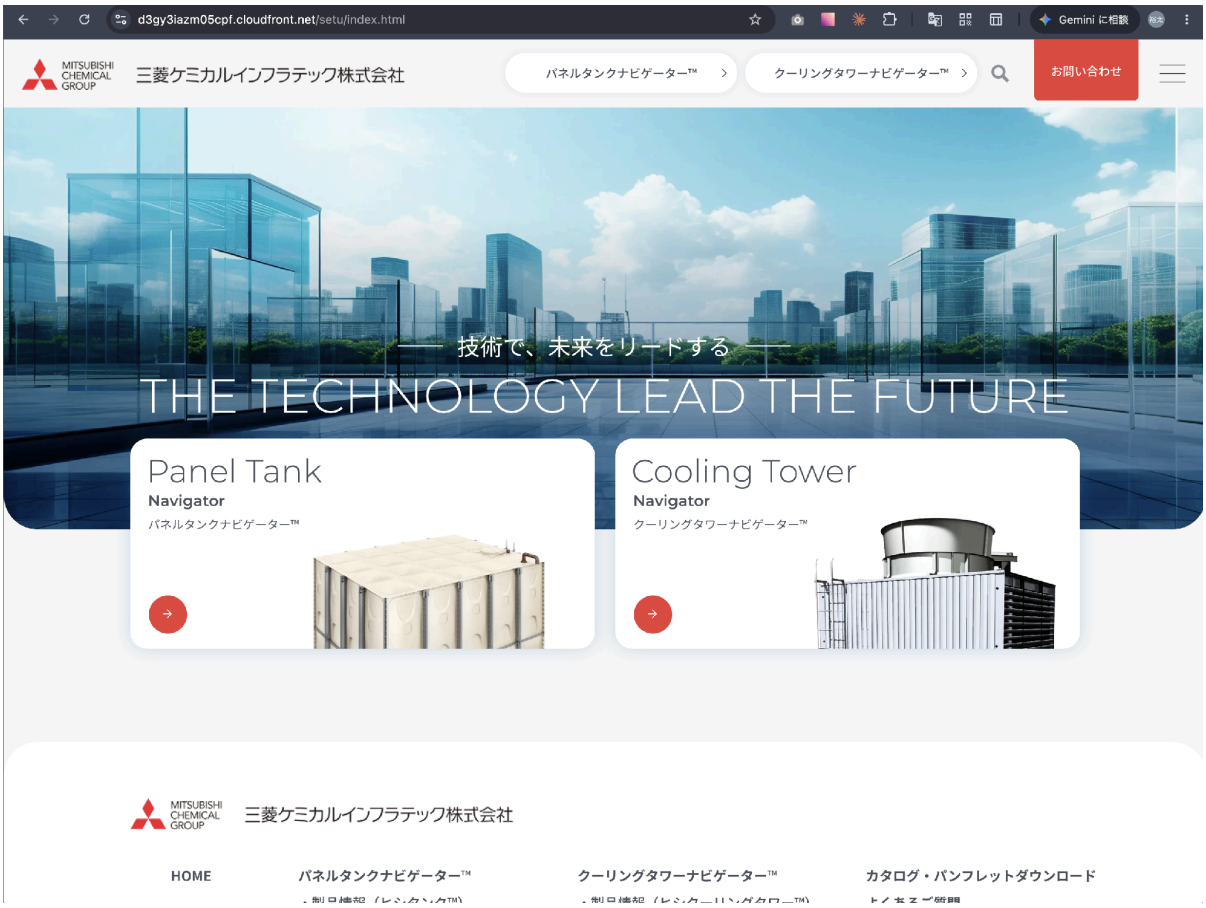
公開ディレクトリと、CMSのプログラム・設定ファイルを分離し、最小限の権限のみを付与しています。Webサーバは権限の弱い専用ユーザ（ログイン不可）で動作させています。

外部から設定ファイル等にアクセスできないことも確認済みです。

確認したファイル	外部からのアクセス結果
.env（環境設定ファイル）	403 拒否
.git/config（バージョン管理情報）	403 拒否
composer.json / wp-config.php / mt-config.cgi	404 存在しない

No.07 正規のサーバ証明書 — 実施済

当サイト専用環境（CloudFront）にはAWSが発行する正規の証明書を、公開URL（mchem-infratec.com）には貴社・アクセンチュア様管理の既存の正規証明書を使用しています。自己署名証明書は使用していません。



▲ CloudFront経由でのHTTPS接続の確認

No.08 アクセスログの取得（サーバ） — 実施済

Webサーバのアクセスログを取得し、AWSのログ管理サービス（CloudWatch Logs）へ自動で集約・保管しています。



▲ Webサーバのアクセスログが記録されていることの確認

No.09 ネットワーク構成要素の最新化 — 実施済

ネットワークを構成する要素（CloudFront、ロードバランサ、仮想ネットワーク等）はすべてAWSのマネージドサービスを利用しています。これらのソフトウェア更新・脆弱性対応はAWSが常時実施しており、利用者側でバージョンが古いまま放置される状態は発生しません（No.02の責任共有モデル参照）。

No.10 ファイアウォールによる通信制限 — 実施済

AWSのファイアウォール機能（セキュリティグループ）により、通信経路ごとに必要な通信だけを許可しています。

- Webサーバへは、ロードバランサ経由の通信のみ許可
- データベースへは、Webサーバからの通信のみ許可（インターネットから直接接続不可）
- サーバ管理用の通信は、許可した保守拠点のIPアドレスからのみ許可

セキュリティグループ

セキュリティグループ名	mchem-infratec-efs-sg				
インバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	ソース	説明
-	NFS	TCP	2049	mchem-infratec-ec2-sg	
アウトバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	送信先	説明
IPv4	すべてのトラフィック	すべて	すべて	0.0.0.0/0	

セキュリティグループ名	mchem-infratec-rds-sg				
インバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	ソース	説明
-	MYSQL/Aurora	TCP	3306	mchem-infratec-ec2-sg	
アウトバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	送信先	説明
IPv4	すべてのトラフィック	すべて	すべて	0.0.0.0/0	

セキュリティグループ名	mchem-infratec-nat-bastion-sg				
インバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	ソース	説明
IPv4	カスタムTCP	TCP	10022	118.243.16.51/32	Used for SSH__TEGOS
IPv4	カスタムTCP	TCP	10022	153.127.199.80/32	Used for SSH__UUUTH
IPv4	カスタムTCP	TCP	587	172.21.0.0/16	Used for SES
IPv4	HTTPS	TCP	443	172.21.0.0/16	Used for SSM and PowerCMS Install
アウトバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	送信先	説明
IPv4	すべてのトラフィック	すべて	すべて	0.0.0.0/0	

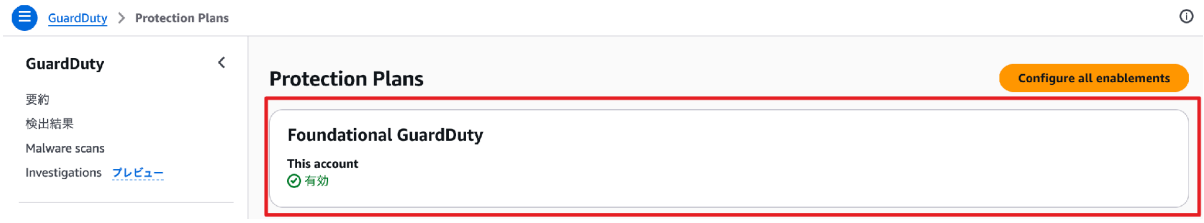
セキュリティグループ名	mchem-infratec-ec2-sg				
インバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	ソース	説明
-	すべてのTCP	TCP	0 - 65535	mchem-infratec-ec2-sg	Used for PowerSync
-	HTTP	TCP	80	mchem-infratec-alb-sg	
-	カスタムTCP	TCP	10022	mchem-infratec-nat-bastion-sg	Used for SSH
-	HTTPS	TCP	443	mchem-infratec-alb-sg	
アウトバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	送信先	説明
IPv4	すべてのトラフィック	すべて	すべて	0.0.0.0/0	

セキュリティグループ名	mchem-infratec-alb-sg				
インバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	ソース	説明
IPv4	HTTPS	TCP	443	0.0.0.0/0	
IPv4	HTTP	TCP	80	0.0.0.0/0	
アウトバウンドルール					
IPバージョン	タイプ	プロトコル	ポート範囲	送信先	説明
IPv4	すべてのトラフィック	すべて	すべて	0.0.0.0/0	

▲ セキュリティグループの設定一覧

No.11 不正侵入検知・防御（IDS/IPS） — 実施済

- **防御（IPS）**：AWS WAF のマネージドルールにより、既知の攻撃パターンを含む通信を自動で遮断しています。
- **検知（IDS）**：AWSの脅威検知サービス Amazon GuardDuty を有効化し、不審な通信や操作を常時検知しています。サーバ上でも検知エージェントが稼働しています。



▲ Amazon GuardDuty が有効化されていることの確認



▲ AWS WAF（保護パック）の適用ルール

No.12 DoS攻撃への対策 — 実施済

CloudFront（AWSのDDoS保護機能 AWS Shield Standard を標準で含む）を経由させ、さらに AWS WAF で同一接続元からの過剰なアクセスを制限しています（No.11の画像を参照）。

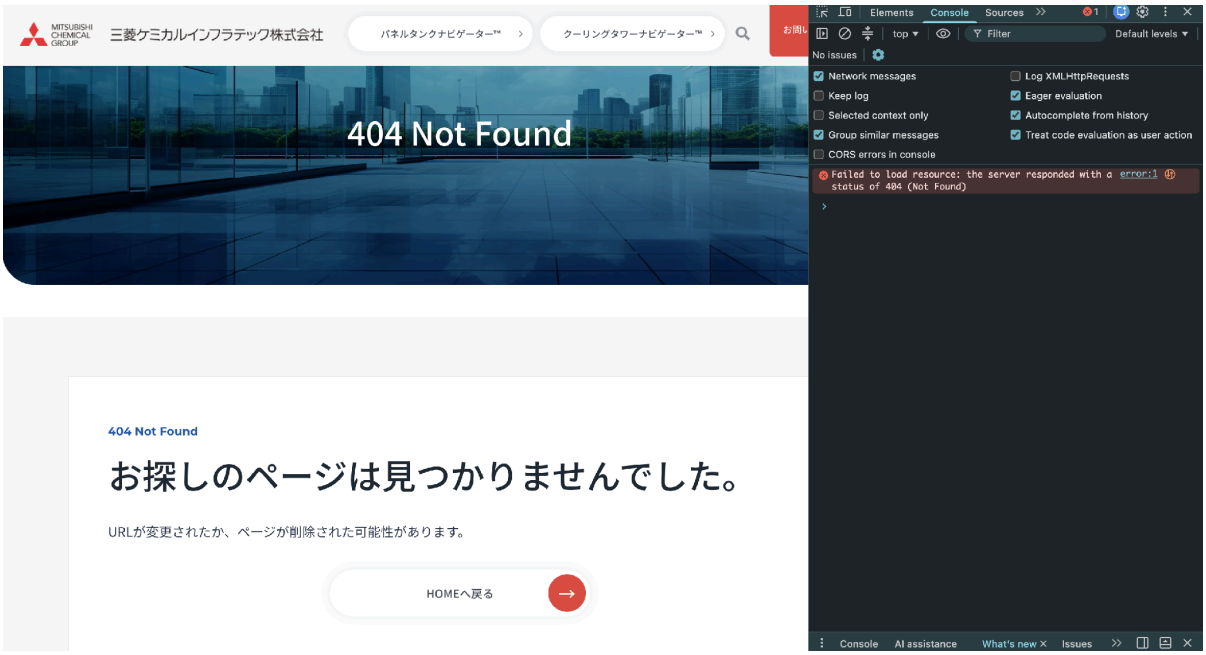
No.13 アクセスログの取得（ネットワーク） — 実施済

CloudFront・ロードバランサ・AWS WAF のアクセスログを取得し、AWSのストレージ（Amazon S3）に保管しています（AWS WAF のログ出力先は、No.11 の AWS WAF の画像の「ログ記録」欄を参照）。

3.2 構築：ウェブアプリケーション

No.14 エラーメッセージの最小化 — 実施済

本番環境ではデバッグ出力を無効にしており、エラー時には汎用のメッセージのみを表示します。サーバの内部情報・ファイルの場所・データベースの情報などは表示しません。



▲ 存在しないページへアクセスした際の表示（内部情報を含まない）

No.15 セキュアコーディング — 実施済

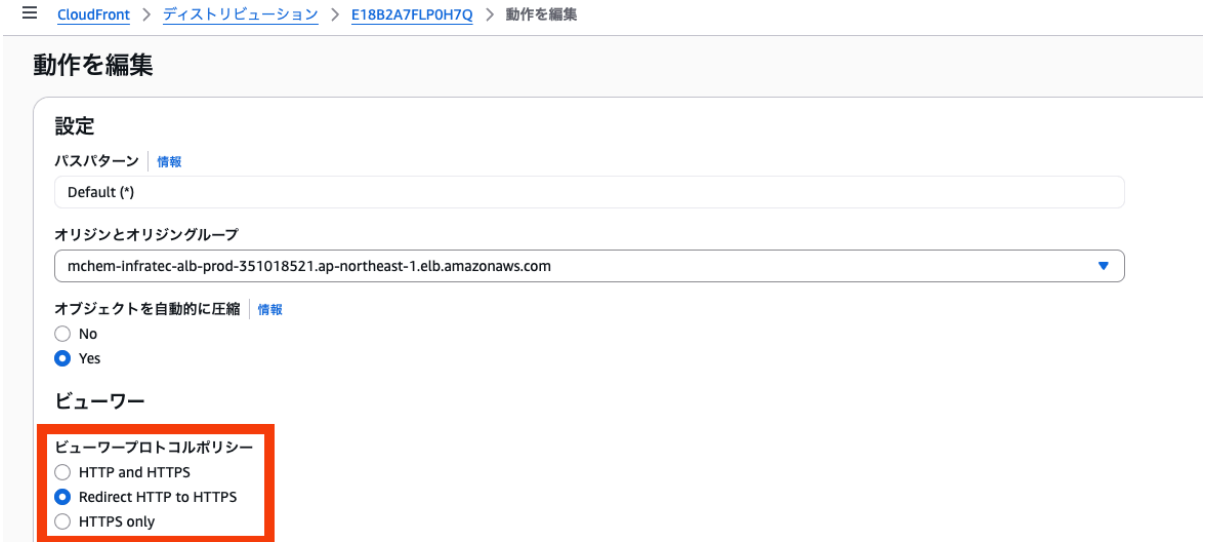
入力値の検証、出力時のエスケープ処理、データベース操作時のプレースホルダ利用など、代表的な脆弱性を作り込まないための実装を行っています。実装の安全性は、外部の専門業者による脆弱性診断（No.22・23）でも確認しています。

No.16 常時HTTPS化 — 実施済

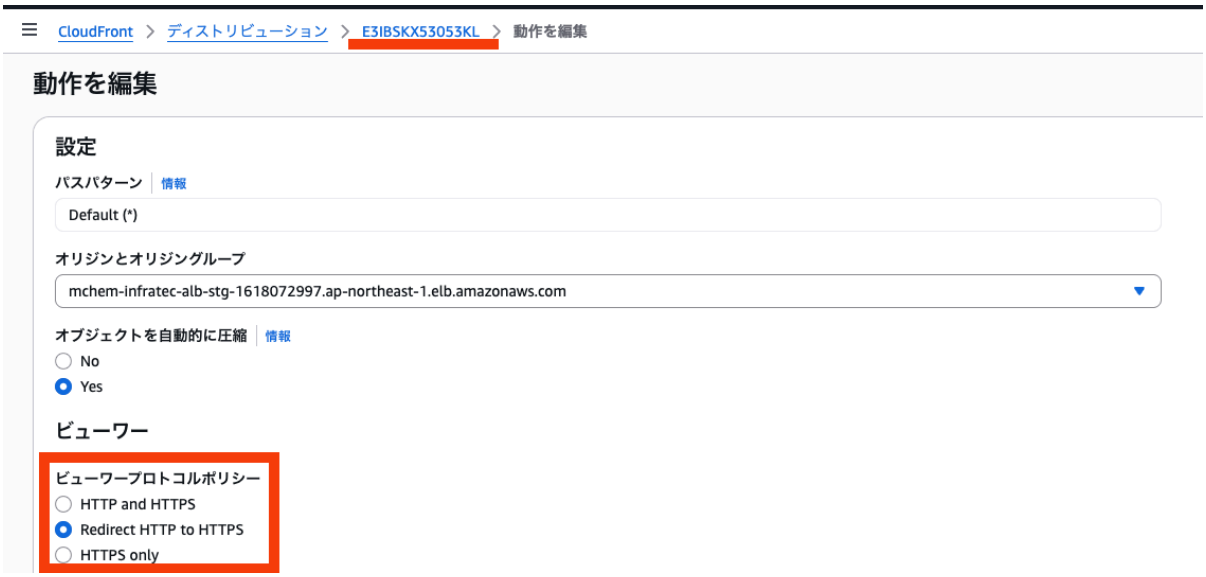
HTTPでのアクセスはすべてHTTPSへ自動で転送する設定としています。本番環境・検証環境の両方で設定済みです。



▲ 本番環境：HTTPをHTTPSへリダイレクト



▲ 本番環境：ビューワープロトコルポリシーの設定



▲ 検証環境：同様の設定

TLSバージョンについて

閲覧者のブラウザが接続するのは公開URL（mchem-infratec.com）のWebサーバであり、閲覧者との暗号化通信のTLSバージョン・暗号スイートは、貴社・アクセンチュア様管理の同サーバの設定に従います。

当サイト専用環境（CloudFront）は、閲覧者が直接アクセスするものではなく、上記Webサーバからの転送を受ける中継先です。CloudFront標準の証明書を使う構成では、受け付けるTLSの最低バージョンがAWSの仕様により「TLSv1」に固定され、利用者側で変更できません。実際の通信では、接続元が対応する最も新しいバージョン（TLS 1.2以上）が自動的に選ばれます。

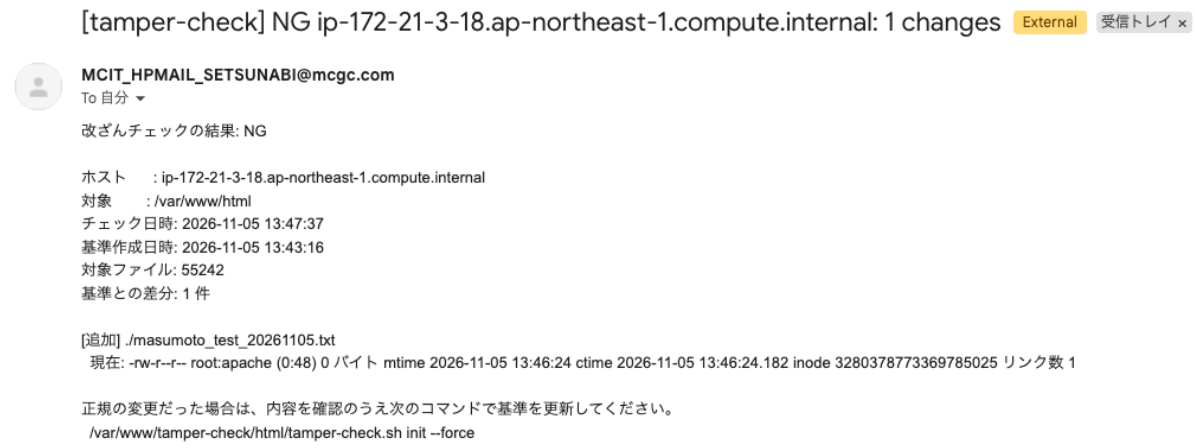


▲ AWS公式ドキュメント：CloudFront標準証明書ではセキュリティポリシーがTLSv1に自動設定される仕様

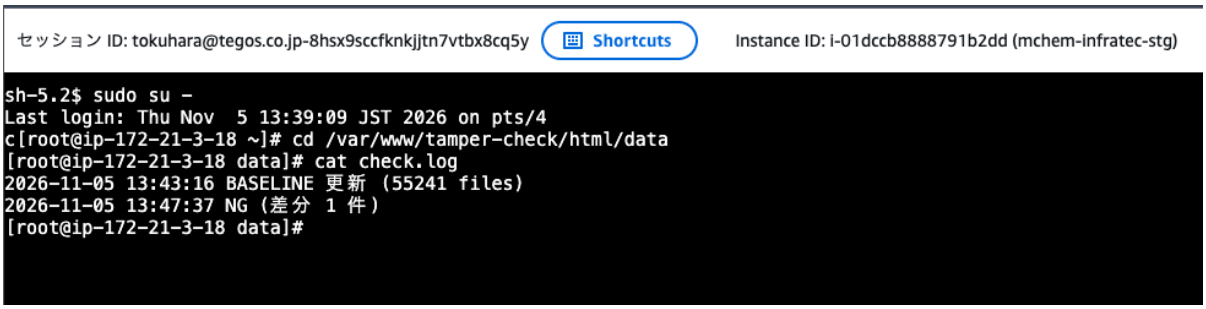
No.17 改ざんの自動検知 — 実施済

公開ファイルの改ざん検知の仕組みを新たに導入しました。定期的に公開ファイル（約5万5千件）を正常時の状態と照合し、追加・変更・削除があった場合は担当者へ自動でメール通知します。

テスト用ファイルを追加して、検知とメール通知が正しく動作することを確認しています。



▲ 改ざん検知時に自動送信されるメール通知



▲ 改ざん検知の実行記録

No.18 WAFの有効化 — 実施済

AWS WAF を CloudFront に適用し、有効化しています。AWSのマネージドルール（一般的な攻撃への対策ルール一式）に加え、当サイト独自のアクセス制限ルールを設定しています。



▲ CloudFrontにAWS WAFが適用・有効化されていることの確認

No.19 入力フォームの不正利用対策 — 実施済

お問い合わせ（見積書・図面依頼）フォームに Google reCAPTCHA を導入し、機械的な大量送信などの不正利用を防いでいます。reCAPTCHA は本番ドメイン（mchem-infratec.com）で有効になるよう設定しており、本番公開と同時に動作を開始します。

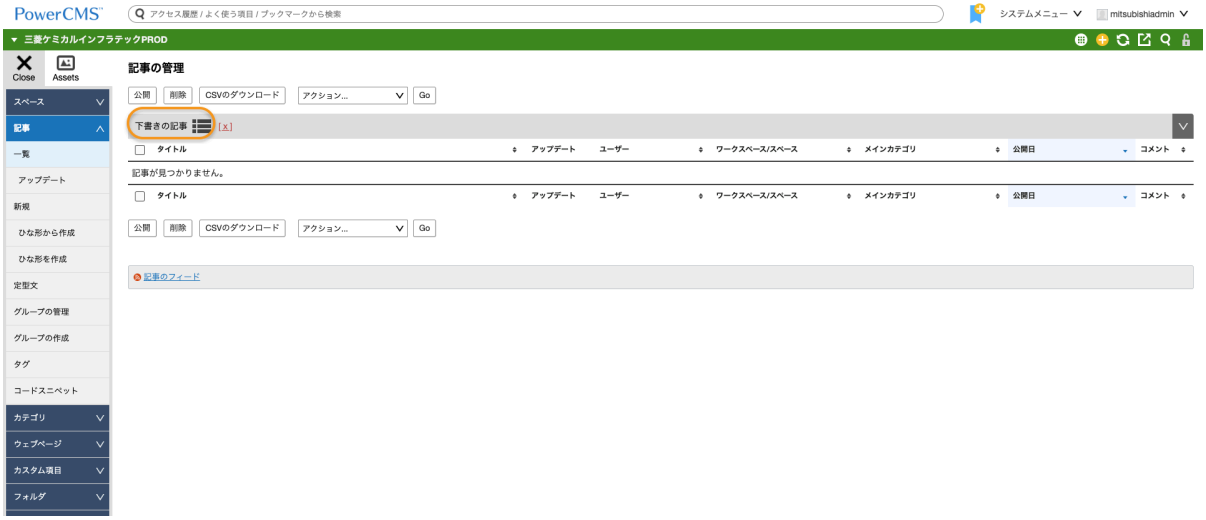
No.20 EMV 3-Dセキュア — 対象外

当サイトにはクレジットカード決済機能がないため、対象外です。

No.21 不要なファイル・ページの削除 — 実施済

開発時に使用した不要ファイル・テストページ・バックアップファイルは、本番環境から削除しています（No.06のアクセス確認もあわせてご参照ください）。

CMS上にも、テスト用の記事や公開予定のない下書き記事は残していません。



▲ CMS：下書き記事が残っていないことの確認

3.3 構築：脆弱性対策

No.22 システム基盤の脆弱性診断 — 実施済

2026年11月、Amazon Inspectorにより脆弱性診断を実施しました。脆弱性の解消を確認しています。

詳細は別添「三菱ケミカル株式会社様向け システム基盤脆弱性診断結果報告書」をご参照ください。

No.23 アプリケーションの脆弱性診断 — 実施済

2026年8月、外部の脆弱性診断専門業者（グローバルセキュリティエキスパート株式会社／GSX社）による脆弱性診断を実施しました。指摘事項はすべて修正し、再診断で解消を確認しています。

詳細は別添「三菱ケミカル株式会社様向け Webアプリケーション 再診断結果報告書」をご参照ください。

3.4 構築：アカウント管理及びアクセス管理

No.24 個人を特定できるアカウント発行 — 実施済

No.25 権限の最小化 — 実施済

CMS（PowerCMS）の管理画面は、現在、管理者1名のみが利用しており、管理者本人に個別に発行したアカウントで運用しています。共有アカウントは使用していません。権限はCMSのロール機能で、業務に必要な範囲に限定しています。

利用者が増える場合も、担当者ごとに個別のアカウントを発行し、必要最小限の権限のみを付与する方針です。なお、当サイトに一般利用者向けのログイン機能はありません。

No.26 パスワードポリシー — 実施済

CMSのパスワード設定（文字数・文字種など）を、貴社「情報システムセキュリティ管理規則 6.17 認証情報」に合わせて設定しています。

No.27 個人情報を扱うアカウントの多要素認証 — 実施済

フォームのお問い合わせ内容（個人情報）はCMS内に保存されるため、CMS管理画面のすべてのアカウントに多要素認証（ワンタイムパスワード）を適用しています（No.30・31の画像参照）。

No.28 連続認証失敗時のロックアウト — 実施済

CMSのアカウントロック機能により、**24時間に10回サインインに失敗した場合はそのアカウントのサインインを、同一IPアドレスから30分間に10回サインインに失敗した場合はそのIPアドレスからのアクセスを禁止** する設定としています。ロック発生時は管理者へメールで通知されます。



▲ アカウントロックの設定（アカウント：24時間に10回、IPアドレス：30分間に10回失敗でロック）



▲ ロック通知メールの送信元設定

No.29 ログの1年以上の保管 — 実施済

アクセスログ・システムログ・監査ログ（CMSの操作履歴を含む）を、CloudWatch Logs および Amazon S3 に1年以上保管する設定としています。

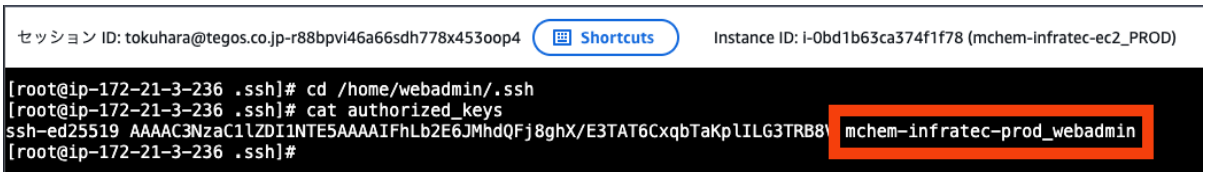
No.30 特権アカウントの個人管理 — 実施済

AWS・サーバ（OS）・CMSの各レイヤで、管理者権限を持つアカウントを管理しています。

レイヤ	管理方法
AWS	担当者ごとにメールアドレス単位のIAMユーザを発行
サーバ（OS）	特権アカウントは管理者1名のみが使用。鍵認証のみでログインし、サーバ操作はAWSの記録付きセッションで実施
CMS	システム管理者アカウントは管理者1名のみが使用し、多要素認証を適用



▲ AWS：担当者ごとのIAMユーザ



▲ サーバ：鍵認証の設定



▲ CMS：管理者アカウント一覧（多要素認証「有効」）

No.31 特権アカウントの多要素認証 — 実施済

レイヤ	認証方式
AWS	全IAMユーザに多要素認証（MFA）を設定済み
サーバ（OS）	鍵認証のみ（パスワードでのログインは無効化）

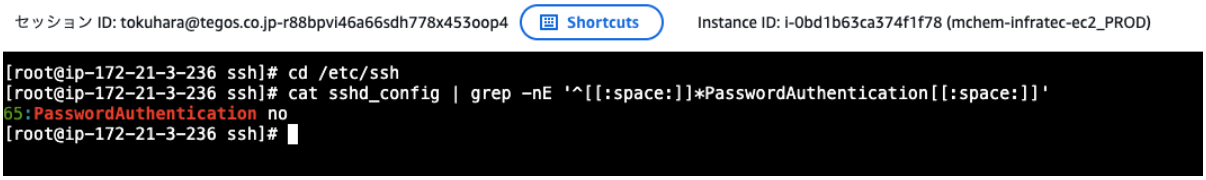
レイヤ	認証方式
CMS	ワンタイムパスワードによる多要素認証を設定済み



▲ AWS：MFA設定済み（担当者1）



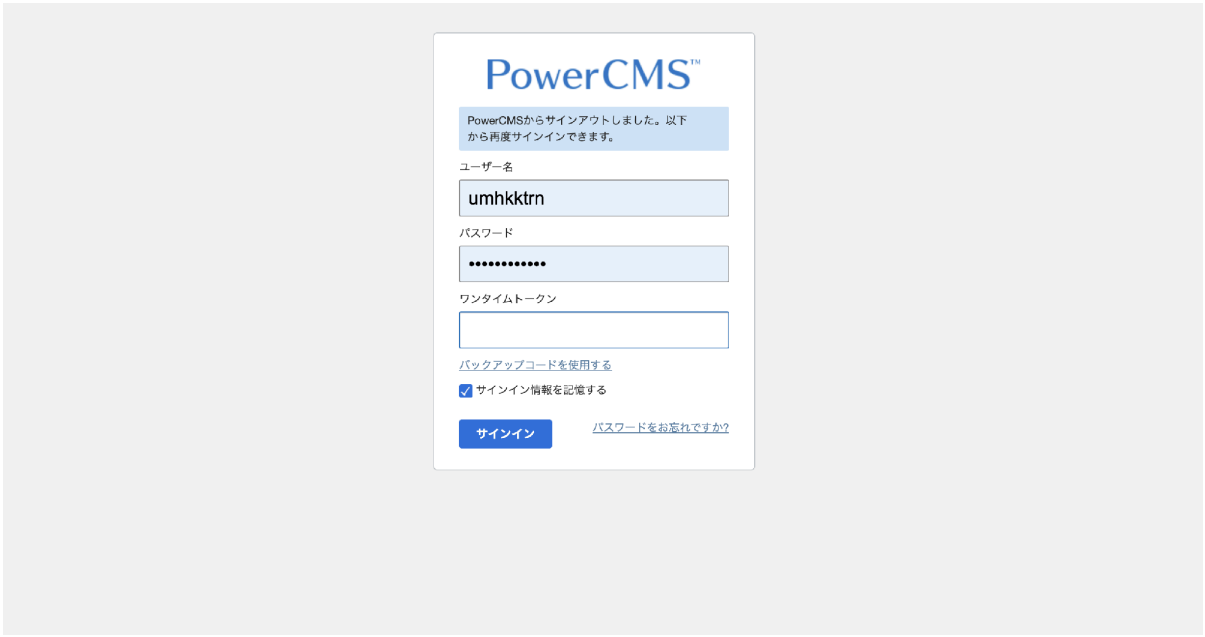
▲ AWS：MFA設定済み（担当者2）



▲ サーバ：パスワード認証の無効化



▲ CMS：多要素認証の設定画面



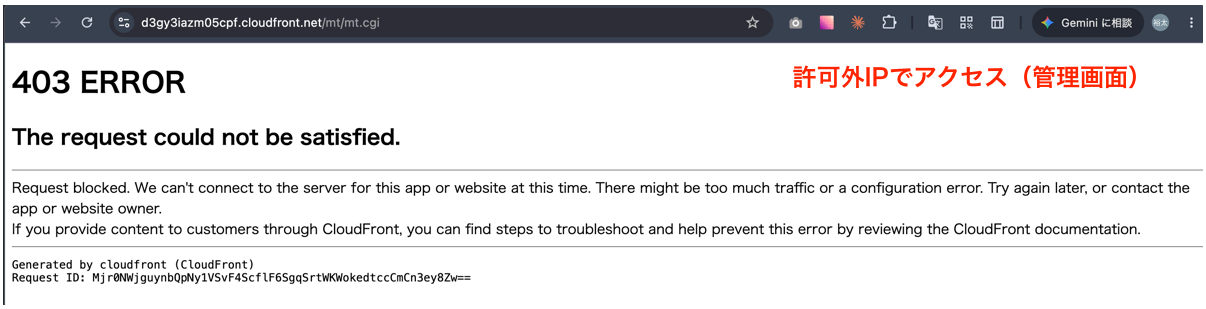
▲ CMS：サインイン時にワンタイムトークンを要求

No.32 管理者ログイン機能を公開しない — 実施済

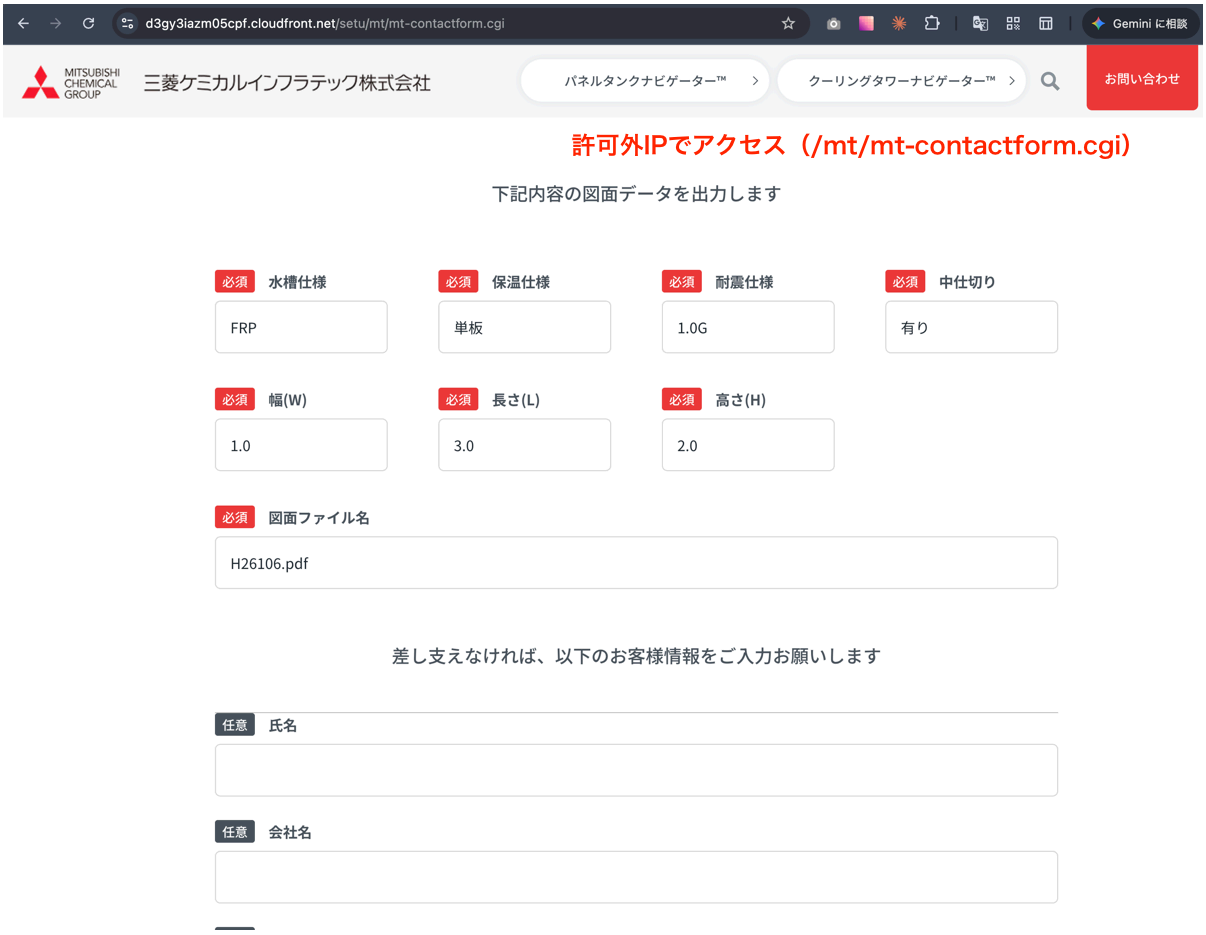
No.33 許可した端末以外からの管理アクセス制限 — 実施済

CMS管理画面は、AWS WAF により **許可したIPアドレス（運用・保守担当拠点）以外からのアクセスをすべて遮断** しています。サーバへの接続も同様に許可IPアドレスからのみに制限しています（No.10参照）。

なお、お問い合わせフォームの送信処理はCMSのプログラムを利用するため、フォームに必要な部分のみ遮断の対象外としています。



▲ 許可外のIPアドレスから管理画面へアクセスした場合：遮断（403）



▲ 許可外のIPアドレスからお問い合わせフォームへアクセスした場合：利用可能

No.34 リモート管理通信の暗号化 — 実施済

サイト管理業務（CMS操作）の通信はHTTPSで、サーバ管理の通信はSSHまたはAWSの暗号化セッション（Session Manager）で行っており、すべて暗号化されています。

3.5 構築：取り扱い情報

No.35 クレジットカード情報の非保持 — 対象外

当サイトにはクレジットカード情報を入力するページがないため、対象外です。

No.36 個人情報保護法への準拠 — 実施予定

国内向けのサイトとして個人情報保護法に準拠しています。個人情報を入力する各フォームに「個人情報の取り扱いについて」（利用目的・管理方法）を初期状態では閉じて掲載し、**任意項目がすべて未入力の場合は同意チェックなしでも利用可能、個人情報を入力した場合は同意チェックを必須**とします。なお、見積書・図面依頼フォームでは同意チェックを必須とします。



▲ パネルタンク 図面ダウンロードフォーム



▲ クーリングタワー 図面ダウンロードフォーム

4. 公開後の運用計画

運用段階の項目（No.37〜48）は、公開後も継続して以下のとおり実施します。月次の作業は保守業務に含めて実施します。

No.	項目	実施内容	頻度・時期	結果
37	運用ドキュメント・体制	「サイト運用の手引き」（Ver.1.0）を作成し、貴社・アドップ・保守担当の運用体制を整備	2026年11月13日の公開までに確定予定	実施予定
38	運用状況の点検	運用体制・ルールの見直し	年1回（毎年10月目安）	公開後の定期運用
39	運用ルールの教育	公開前に運用担当者向け説明を実施、以降も継続	年1回	公開後の定期運用
40	証明書の維持管理	当サイト環境の証明書はAWSが自動更新。公開URLの証明書は貴社・アクセンチュア様にて管理	自動	実施済
41	不要ファイル・ページの確認	公開不要なファイル・ページがないかを点検	年1回（毎年10月目安）	公開後の定期運用
42	アプリケーションログの確認	ウェブアプリケーションのログを確認	月1回	公開後の定期運用
43	WAF設定の点検	WAFのログ・検知状況から設定の有効性を点検	月1回	公開後の定期運用
44	アクセス権の棚卸し	CMS・AWSのアカウントと権限の妥当性を確認	年1回（毎年10月目安）	公開後の定期運用
45	異動・退職時の対応	貴社からのご連絡を受け次第、アカウントの無効化・権限変更を実施	随時	公開後の定期運用
46	不正アクセスの確認	アクセスログ・認証ログから不正アクセスの有無を点検	月1回	公開後の定期運用
47	脆弱性情報の収集	JVN・IPA、PowerCMS開発元、AWS等のセキュリティ情報を常時収集し、影響有無を確認	常時	実施済
48	定期的な脆弱性診断	実施方法は別途協議とする	年1回（次回2027年8月目安）	公開後の定期運用

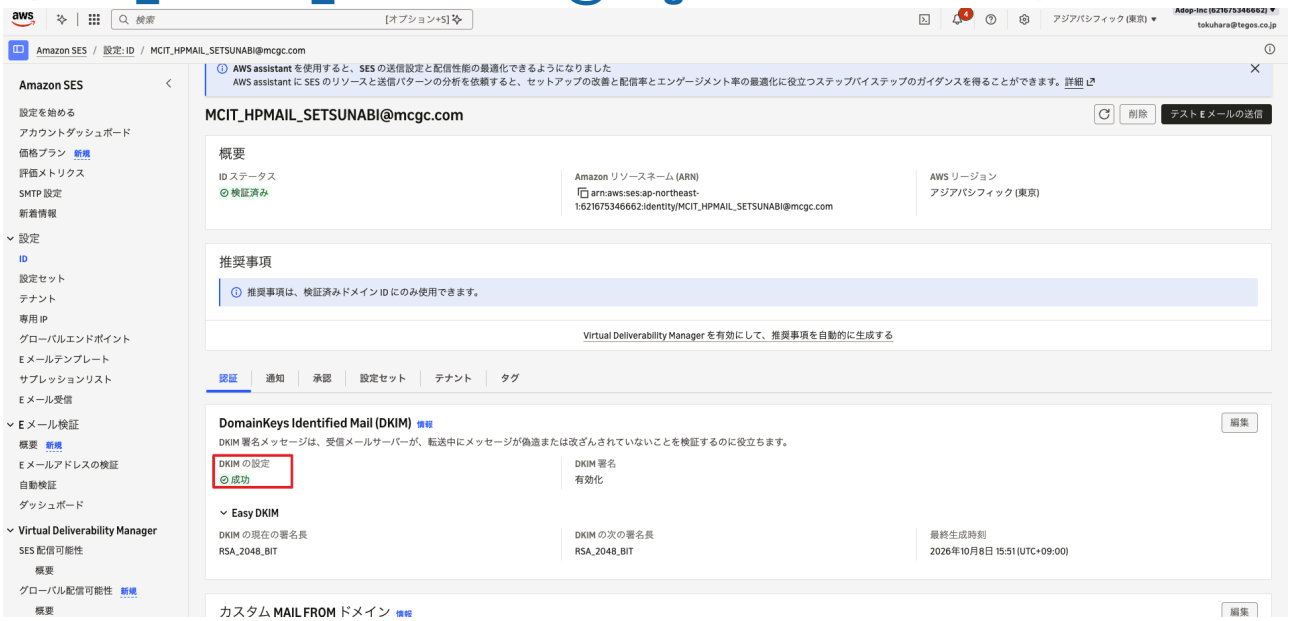
あわせて、AWS GuardDuty（脅威検知）と改ざん検知（No.17）は常時稼働し、異常時は担当者へ自動通知されます。

5. 別添資料

資料名	内容
別紙1 公開ウェブサイト届出シート	届出内容
別紙2 公開ウェブサイト セキュリティ対策チェックリスト	全48項目の対応状況
三菱ケミカル株式会社様向け システム／Webアプリケーション 再診断結果報告書（GSX社）	No.15・22・23 の根拠資料
サイト運用の手引き Ver.1.0	No.37 の根拠資料

6. 2026年11月12日追加

（MCIT_HPMAIL_SETSUNABI@mcgc.com のDKIM証跡）



以上